

SISR**CAS BLOOM**

Durée : 4 heures

Barème

DOSSIER A	Dossier A – Diagnostic de la situation actuelle et apport de solutions à court terme	36 points
DOSSIER B	Dossier B – Apport de solutions à long terme	32 points
DOSSIER C	Dossier C – Exploitation du SI	12 points
	TOTAL	80 points

Éléments de correction

Présentation du contexte

La société Bloom est une cristallerie de luxe française implantée sur plusieurs sites. Le siège de Bloom est situé à Pannes-en-Argonne. On y trouve l'usine principale du groupe, où sont produits la plupart des objets en catalogue, et une boutique. Le site abrite également le « centre des maîtres verriers » qui est tout à la fois un lieu de démonstration du savoir-faire des ouvriers, un laboratoire de recherche et une « pépinière » de jeunes créateurs, dont la production est vendue au sein de la boutique locale.

L'usine historique de Sciaux produit essentiellement des pâtes de verre et les plus beaux objets du catalogue.

Le site de Paris abrite les bureaux du service marketing et du webmestre du site de la société actuellement hébergé chez un prestataire.

Le groupe dispose d'un réseau de 12 boutiques (bientôt 30) réparties sur tout le territoire français et d'un réseau de boutiques situées dans de grandes villes d'une trentaine de pays. Seules les boutiques françaises sont reliées en réseau avec le siège.

Il est important pour la société Bloom d'avoir un système d'information et de communication performant, car les échanges entre les différents sites sont nombreux et essentiels. Par ailleurs, de nombreuses informations sensibles (comme les données de fabrication) circulent. La confidentialité de ces données est une priorité pour l'entreprise.

Récemment, **trois problèmes majeurs** obligent le responsable informatique de Bloom à réaliser un diagnostic afin de prendre les décisions qui s'imposent de manière à assurer la sécurité de son système d'information.

Le premier problème auquel est confrontée la société Bloom tient à la fragilité des liaisons informatiques entre ses différents sites : le siège de la société, situé en pleine campagne, à Pannes-en-Argonne, a récemment été coupé pendant 24 heures des autres sites et de l'Internet suite au sectionnement par un engin de travaux publics du fourreau qui abritait à la fois le câble de sa liaison SDSL principale et celui de sa liaison de secours.

Le second problème est lié à la vétusté des routeurs « cœurs de réseau » des boutiques, notamment celle de Paris qui héberge le service marketing et le webmestre, ce qui fait craindre une panne à venir.

Le troisième problème s'est concrétisé par une attaque de déni de service (DoS) récente sur le site vitrine de la société Bloom : lorsque les clients tentaient de se connecter au site, celui-ci affichait le message suivant : « impossible de se connecter au serveur distant ».

Vous faites partie de l'équipe technique du service informatique de la société Bloom chargée de :

- proposer et de mettre en œuvre des solutions à court, à moyen et à long terme afin de répondre en priorité à ces différentes problématiques ;
- répondre aux incidents de sécurité.

Vous vous appuyerez sur le dossier documentaire mis à votre disposition.

Dossier A – Diagnostic de la situation actuelle et apport de solutions à court terme

Avant la réalisation de changements dans le SI de la société Bloom, il vous est demandé d'évaluer les risques liés aux trois problèmes survenus en réalisant un diagnostic du SI.

Mission A1 – Analyse des risques des trois problèmes relevés et apport de solution à court terme pour le troisième problème (22 points)

Le responsable du service informatique vous demande de mettre en œuvre la méthode EBIOS Risk Manager (dont un résumé est fourni dans le dossier documentaire) pour hiérarchiser les risques liés aux trois problèmes cités précédemment dans la description du contexte :

- faiblesse de la liaison inter-sites ;
- panne du cœur de réseau du site de Paris ;
- attaque de déni de service (DoS) du site vitrine.

La classification des risques doit permettre au service informatique de planifier la mise en place de solutions appropriées.

Question A1.1

- a) Analyser la **vraisemblance** de chacun des trois problèmes et la **gravité des risques** qu'ils peuvent engendrer pour le système d'information. *Justifier la réponse.*
b) Proposer un ordre de priorité dans la planification des solutions.

Compétences visées du référentiel :

- Garantir la disponibilité, l'intégrité et la confidentialité des services informatiques et des données de l'organisation face à des cyberattaques
 - Caractériser les risques liés à l'utilisation malveillante d'un service informatique
 - Recenser les conséquences d'une perte de disponibilité, d'intégrité ou de confidentialité

12 points : (2 point par indicateur justifié : 2*6)

a)

Vraisemblance :

* Faiblesse de la liaison inter-sites : peu vraisemblable qu'une pelleteuse revienne couper un câble (**V1**). *Un autre niveau de vraisemblance a été accepté si justifié (par exemple par le fait qu'il puisse être coupé lors d'une tempête et que le fait que les deux liens soient dans le même fourreau puisse de nouveau entraîner la coupure simultanée des deux liens)*

* Panne du cœur de réseau du site de Paris : vraisemblable. En effet une panne d'un routeur vieillissant n'est pas une exception. (**V2**).

* Attaque du site vitrine : Très vraisemblable que cela se reproduise si rien n'est fait pour empêcher ou limiter une telle attaque puisque ce type d'attaque DOS est courant (**V3**).

Gravité :

* Faiblesse de la liaison inter-sites : Grave si cette panne se situe sur le site hébergeant l'ensemble des serveurs de la société car cela entraînera une paralysie de l'activité, de nombreux éléments ne peuvent plus communiquer comme les boutiques qui ne pourront plus accéder aux applications métiers (**G3**).

* Panne du cœur de réseau du site de Paris : Significative. Le pôle marketing et le webmestre seraient touchés par la rupture de service ainsi que les utilisateurs de la boutique de Paris. Le périmètre reste cependant limité (**G2**).

* Attaque DOS du site vitrine : Grave. Les clients ne peuvent plus acheter en ligne et peuvent se détourner vers un autre site (risques financiers importants). Par ailleurs, l'image de la société Bloom pourrait être ternie (**G3**).

b) Ordre de priorité (2 points)

* Attaque du site vitrine : **V3 + G3** ⇒ **priorité 6**

* Faiblesse de la liaison inter-sites : **V1 + G3** ⇒ **priorité 4**

* Panne du cœur de réseau du site de Paris : **V2 + G2** ⇒ **priorité 4**

Question A1.2

Préciser le ou les critères de sécurité « DIC » impactés par chacun des trois problèmes présentés.

Compétences visées du référentiel :

- Garantir la disponibilité, l'intégrité et la confidentialité des services informatiques et des données de l'organisation face à des cyberattaques
 - Caractériser les risques liés à l'utilisation malveillante d'un service informatique

3 points : 1 point par critère (3)

* Faiblesse de la liaison inter-sites : critère de disponibilité

* Panne du cœur de réseau du site de Paris : critère de disponibilité

* Attaque du site vitrine : critère de disponibilité

En ce qui concerne l'attaque DoS sur le site web, votre responsable a l'idée de mettre en place une solution de supervision afin d'alerter au plus tôt si le problème se produit de nouveau. Il a listé les commandes de l'outil de supervision et il vous demande de fournir des explications techniques qui aideront à la configuration.

Question A1.3

Citer les commandes de l'outil de supervision qui permettront d'alerter au plus tôt en cas de nouvelle attaque sur le site web et justifier leur usage dans le cas d'une attaque par déni de service (DoS).

Compétences visées du référentiel :

- Assurer la cybersécurité d'une infrastructure réseau, d'un système, d'un service
 - Détecter les actions malveillantes

3 points (1 point par commande)

Pour vérifier la bonne santé d'un serveur web, il faut surveiller le trafic (check_traffic), la charge CPU du serveur (check_snmp_cpu), le nombre de processus actifs (check_procs), si l'hôte répond et les temps de réponse du ping (check_ping).

Les alertes permettront de savoir s'il y a un nombre de connexions trop important par rapport à la consultation normale, ou trop de processus ouverts.

Elles permettront aussi de savoir si le serveur web répond dans des délais corrects tant au niveau du ping que du temps de réponse du site web.

Question A1.4

Donner deux moyens de se prémunir d'une attaque DoS.

Compétences visées du référentiel :

- **Assurer la cybersécurité d'une infrastructure réseau, d'un système, d'un service**
 - Prévenir les attaques

2 points (1 point par moyen)

Règles écrites dans le firewall

Mise en place d'un IPS.

Répartition de charges, mise en place d'un reverse proxy, augmentation de la bande passante (ce qui permet uniquement de réduire l'impact).

Mission A2 – Analyse d'un risque d'attaque par injection SQL du site vitrine (14 points)

Le site vitrine a été développé il y a quelques années et aucun audit n'a été réalisé depuis. Le responsable informatique redoute une attaque par injection SQL qui permettrait de consulter et modifier les données « clients » stockées chez le prestataire d'hébergement.

Question A2.1

- Justifier en quoi les données ciblées constituent des données à caractère personnel.
- Identifier quelle obligation issue du règlement général sur la protection des données (RGPD) ne serait plus respectée.
- Préciser l'acteur responsable juridiquement : la société Bloom ou le prestataire d'hébergement de sites Web.

Compétences visées du référentiel :

- **Protéger les données à caractère personnel**
 - Identifier les risques liés à la collecte, au traitement, au stockage et à la diffusion des données à caractère personnel
 - Appliquer la réglementation en matière de collecte, de traitement et de conservation des données à caractère personnel
 - CEJMA : Les données à caractère personnel

6 points : 2 points par sous-question (2*3)

a. Par lecture de l'extrait de la table « clients » nous constatons que les données stockées (nom, prénom, adresse, code postal, ville) permettent d'identifier chacun d'eux.

b. L'obligation générale de sécurité et de confidentialité ne serait plus respectée.

D'une manière générale, les obligations du responsable de traitements des données sont :

- la transparence et la traçabilité
- **la prise en compte de la protection des données dès la conception**
- garantir la sécurité et la confidentialité des données traitées
- l'assistance, l'alerte et le conseil

c. L'engagement 4 concernant la sécurité des données hébergées est clair : le client (donc Bloom dans notre cas) est seul responsable de la sécurisation des ressources et des systèmes applicatifs qu'il déploie, dans le cadre de l'utilisation de nos services.

Question A2.2

Préciser le ou les critères de sécurité « DIC » impactés par cette potentielle attaque.

Compétences visées du référentiel :

- Garantir la disponibilité, l'intégrité et la confidentialité des services informatiques et des données de l'organisation face à des cyberattaques
 - Caractériser les risques liés à l'utilisation malveillante d'un service informatique

2 points

Critère de sécurité : confidentialité et intégrité (Il s'agit d'une attaque par injection SQL, si elle réussit le hacker peut consulter voire modifier les données « clients » qui sont des données à caractère personnel.

Question A2.3

Identifier les risques économiques, juridiques et identitaires pour la société Bloom qui découlerait de cette attaque.

Compétences visées du référentiel :

- Protéger les données à caractère personnel
 - Appliquer la réglementation en matière de collecte, de traitement et de conservation des données à caractère personnel
- Protéger l'identité numérique d'une organisation
- CEJMA : Les risques des cyberattaques pour l'organisation : économique, juridique, atteinte à l'identité de l'entreprise.

6 points (2 points par risque)

Risques économiques : perte de chiffre d'affaires et perte de clients du fait d'une perte de confiance et d'une éventuelle interruption de service pour régler le problème. Par ailleurs, Bloom pourrait être amené à payer des amendes si une action en justice était entamée.

Risques juridiques : Selon le contrat de service avec le prestataire, la société Bloom est responsable et elle devra supporter les éventuelles recours en justice des clients.

Risques identitaires : Perte de confiance des clients par le manque de sécurité apporté sur la protection des données à caractère personnel. Le recrutement de futurs salariés qualifiés peut être plus difficile suite à la perte d'image de l'organisation.

Dossier B – Apport de solutions à long terme

Suite à l'analyse précédente, deux projets sont en cours de déploiement : le transfert de l'hébergement des serveurs vers la société *Herbetek* et la mise en place d'une haute disponibilité du cœur de réseau sur le site de Paris.

Mission B1 – Analyse du contrat d'hébergement des serveurs chez Herbetek (20 points)

Avant de signer le contrat d'hébergement et de transférer leurs serveurs depuis le siège de Pannes-en-Argonne au sein de la ferme d'hébergement d'Herbetek, les responsables de la société Bloom souhaitent qu'une réunion soit organisée pour leur permettre d'approfondir ce que va leur apporter cette solution et demander d'éventuels éclaircissements au futur prestataire.

Les responsables de Bloom vous ont transmis par avance une liste de questions à préparer.

Question B1.1

Préparer des éléments de réponse convaincants aux questions techniques posées par les responsables de Bloom et en particulier par ceux qui travaillent au siège de Pannes-en-Argonne.

- « Si le coup de pelleuse se reproduit, comme la dernière fois, au même endroit je ne vois pas ce qui va changer. »
- « Expliquez-moi comment Herbetek garantit que son trafic réseau sera séparé de celui des autres clients »
- « Le dispositif mis en place par Herbetek pour la sauvegarde de nos données métier est-il conforme aux recommandations de l'ANSSI ? »
- « Quelles sont les garanties mise en place par l'infrastructure VPN » et quels seraient les risques pour la société Bloom si elle n'utilisait pas une infrastructure VPN pour accéder aux applications distantes ?
- « Quel est l'intérêt du serveur proxy que loue Herbetek ? Pourquoi centraliser la sortie de nos postes sur Internet ? »
- « Pourquoi répartir nos serveurs de mail et web dans une DMZ publique, notre serveur ERP dans une autre DMZ privée, et nos autres serveurs dans notre VLAN dédié ? »

Compétences visées du référentiel :

- **Assurer la cybersécurité d'une infrastructure réseau, d'un système, d'un service**
 - Participer à la vérification des éléments contribuant à la sûreté d'une infrastructure informatique
 - Prendre en compte la sécurité dans un projet de mise en œuvre d'une solution d'infrastructure

16 points (2+2+3+5+2+2)

a. « Si, cela change beaucoup de choses ! Le coup de pelleuse coupera la liaison entre le siège et les serveurs centraux, mais pas celles entre les serveurs centraux et les autres sites, et notamment, l'accès des boutiques et de l'internet public. Une grande partie du système continuera de fonctionner, mais en mode dégradé, sans alimentation de données à partir du siège (de l'usine notamment). »

b.

Herbetek garantit que le trafic réseau de Bloom sera séparé de celui des autres clients par la technologie des VLAN (VLAN 195 pour Bloom) qui **isole de manière hermétique chaque réseau** et des pare-feux virtuels isolant les réseaux des clients. Chaque client verra uniquement ses machines placées dans un VLAN qui lui est strictement propre, avec son propre plan d'adressage IP, si besoin.

c. Les sauvegardes sont régulières et automatisées à partir d'un VLAN connectant tous les systèmes à sauvegarder sur une prise Ethernet dédiée de chacune des machines. Les données sont sauvegardées à la fois sur disque et sur bande avec placement en armoire forte. Elles sont chiffrées et les bandes sont sauvegardées à part ⇒ cela paraît conforme aux recommandations (sauvegardes régulières, supports externes rangées ensuite dans un lieu éloigné, sauvegardes chiffrées pour préserver la confidentialité, etc.).

d. La société Bloom utilise l'accès distant pour récupérer des données sensibles comme les données de fabrication. Si elle n'utilisait pas d'infrastructure VPN qui garanti :

- l'authentification du client et du serveur via la paire de clé (publique/privée),
- la confidentialité des données échangées par chiffrement,
- l'intégrité des données échangées par fonction de hachage et signature,

elle risquerait :

- la connexion d'un client non autorisé et la possibilité pour ce dernier de récupérer des fichiers sensibles sur le serveur ;
- la connexion d'un client à un serveur pirate non authentifié reproduit à l'identique mais contenant des « faux » fichiers ;
- une écoute sur le réseau et donc un vol des données sensibles.

e. La **sortie** sur l'internet via un seul accès unique centralisé permet de **mieux contrôler cette sortie** (sites web en liste blanche ou noire, filtrage horaire, etc.).

f. Cette répartition VLAN Client / DMZ publique / DMZ privée offre les meilleures garanties de sécurité anti-intrusion. Le serveur web, qui est le plus exposé, se trouve dans un premier sas, il aura le droit d'échanger des informations avec le serveur ERP, mais pas avec le reste des serveurs du client Bloom. Le serveur ERP pourra échanger des informations avec les serveurs du VLAN du client, notamment depuis les machines TSE qui font tourner les applications « métiers » du client Bloom.

Question B1.2

Donner les avantages de faire héberger ses serveurs au sein de la ferme Hebertek :

- a. Sur le plan de la disponibilité des communications vers les serveurs hébergés ;
- b. Sur le plan de la sécurité physique des serveurs.

Compétences visées du référentiel :

- Garantir la disponibilité, l'intégrité et la confidentialité des services informatiques et des données de l'organisation face à des cyberattaques
- Assurer la cybersécurité d'une infrastructure réseau, d'un système, d'un service

4 points : 2 points par sous-question (2*2)

a.

La ferme de serveurs Hebertek est « alimentée » par quatre FAI de FAI différents, offrant un haut niveau de garantie. Il y a très peu de risque que la ferme soit coupée de l'Internet.

b.

La sécurité physique des serveurs est assurée par une batterie d'équipements spécialisés : climatisation, onduleurs, générateurs électriques, protection anti-incendie, protection anti-intrusion avec accès sécurisé par badge, redondances diverses sur les machines : des alimentations, disques RAID, des liens SAN, etc.

Mission B2 – Mise en place d'une haute disponibilité du routeur « cœur » de réseau sur le site de Paris (12 points)

Afin de palier au manque de disponibilité du routeur « cœur » de réseau du site de Paris vous avez préparé un prototype mobilisant le protocole HSRP de Cisco. Malgré vos efforts, vous constatez que suite à un test de basculement du routeur principal vers le routeur secondaire, le réseau du site de Paris ne peut plus joindre Internet.

Question B2.1

Proposer une modification de la configuration des routeurs concernés pour permettre le bon fonctionnement du basculement des routeurs. *Justifier la réponse.*

Compétences visées du référentiel :

- Assurer la cybersécurité d'une infrastructure réseau, d'un système, d'un service
 - Participer à la vérification des éléments contribuant à la sûreté d'une infrastructure informatique
 - Mettre en œuvre et vérifier la conformité d'une infrastructure à un référentiel, une norme ou un standard de sécurité

12 points (3 points pour la proposition du tracking + 9 points sur la mise en œuvre)

Par lecture et analyse des documents, l'étudiant doit arriver à proposer l'ajout d'un « tracking » sur le routeur RBL1 qui doit permettre le basculement de l'ensemble des interfaces vers le même routeur afin d'assurer la continuité de service.

Routeur RBL1

```
interface GigabitEthernet0/0
```

```
ip address 192.168.0.3 255.255.255.248
```

```
standby 1 ip 192.168.0.1
```

```
standby 1 priority 105
```

```
standby 1 track GigabitEthernet0/1
```

```
standby 1 track GigabitEthernet0/2
```

```
standby 1 preempt
```

```
!
```

```
interface GigabitEthernet0/1
```

```
ip address 192.168.2.61 255.255.255.192
```

```
standby 2 ip 192.168.2.62
```

```
standby 2 priority 105
```

```
standby 2 track GigabitEthernet0/0
```

```
standby 2 track GigabitEthernet0/2
```

```
standby 2 preempt
```

```
!
```

```
interface GigabitEthernet0/2
```

```
ip address 192.168.2.77 255.255.255.240
```

```
standby 3 ip 192.168.2.78
```

```
standby 3 priority 105
```

```
standby 3 track GigabitEthernet0/1
```

```
standby 3 track GigabitEthernet0/0
```

```
standby 3 preempt
```

Mission C1 – Exploitation de l'infrastructure VPN (6 points)

L'ensemble des postes de chaque site passe par le réseau Internet privé (infrastructure VPN) Daixone (filiale d'Hertebek) pour accéder aux serveurs hébergés.

Dix nouveaux portables qui seront utilisés par les ingénieurs commerciaux doivent être installés et configurés pour pouvoir accéder à n'importe quel moment et de n'importe quel lieu au VPN.

Question C1.1

Lister en les justifiant les actions à réaliser sur le serveur VPN et sur chaque portable afin de permettre l'accès distant via le VPN.

Compétences visées du référentiel :

- Assurer la cybersécurité d'une infrastructure réseau, d'un système, d'un service
 - Mettre en œuvre et vérifier la conformité d'une infrastructure à un référentiel, une norme ou un standard de sécurité
 - Prévenir les attaques

4 points

Sur le serveur et sur chaque portable :

- Installer Wireguard
- **Créer une paire de clé et modifier les droits sur les fichiers générés**
- **Configurer le service (section Interface et section Peer)**
- Lancer le service

Puis échange des clés publiques via un moyen sécurisé.

Le nombre croissant de portables utilisés notamment par les ingénieurs commerciaux augmente la possibilité d'un vol. Vous devez préparer cette éventualité en écrivant une procédure.

Question C1.2

Expliquer en justifiant votre réponse l'action à réaliser sur le serveur VPN en cas de vol d'un portable afin que ce dernier ne mette pas en danger la sécurité de l'entreprise.

Compétences visées du référentiel :

- Assurer la cybersécurité d'une infrastructure réseau, d'un système, d'un service
 - Prévenir les attaques

2 points

Le vol compromet la clé privée créée sur le portable ⇒ il faut immédiatement enlever la configuration se référant à la clé publique (qui permet l'authentification du portable) correspondante.

Mission C2 : gestion d'un incident de sécurité (6 points)

Les utilisateurs des boutiques vous font remonter un dysfonctionnement récurrent. Vous disposez d'une des fiches d'incident avec le message d'erreur affiché par leurs navigateurs lorsque leur demande de connexion est dirigée vers le serveur physique H-TSE-1 du Cluster. Le même problème apparaît la première fois que leur tentative de connexion est dirigée vers le serveur physique H-TSE-2 ou H-TSE-3.

Question C2.1

Expliquer les causes de l'apparition de ce message.

Compétences visées du référentiel :

- Assurer la cybersécurité d'une infrastructure réseau, d'un système, d'un service
 - Analyser les incidents de sécurité, proposer et mettre en œuvre des contre-mesures

3 points

Lorsque l'on se connecte au serveur TSE sécurisé, ce dernier présente au client un certificat afin qu'il puisse vérifier l'identité du serveur. Ce certificat contient des informations d'identité (telles que le nom du serveur et l'autorité qui a créé le certificat). **Le certificat doit pouvoir être vérifié par un tiers approuvé par l'ordinateur via lequel on se connecte.**

Cette alerte de sécurité veut dire que le certificat n'a pas été émis par un tiers connu. Cette situation est ici normale, car la société Bloom n'a pas eu recours à un tiers de confiance mais a généré son propre certificat.

Question C2.2

Proposer deux alternatives pour résoudre cet incident.

Compétences visées du référentiel :

- Assurer la cybersécurité d'une infrastructure réseau, d'un système, d'un service
 - Analyser les incidents de sécurité, proposer et mettre en œuvre des contre-mesures

3 points

Pour résoudre ce problème en toute sécurité, il faut soit **importer le certificat racine de l'entreprise** en tant que « certificat racine » dans le navigateur des postes des boutiques (le certificat doit apparaître dans la liste des certificats des autorités principales de confiance), soit acheter le certificat du site web auprès d'une autorité de certification mondialement reconnue. Ces solutions font disparaître le problème.

Il n'est évidemment pas conseillé de « faire confiance à ce certificat pour les prochaines sessions ».